Seguridad en Redes y Análisis Inteligente de Amenazas

Tema 3. Arquitecturas de seguridad en redes

Índice

Esquema

Ideas clave

3.1. Introducción y objetivos

3.2. Zonas de una infraestructura de red

3.3. Topologías de defensa

3.4 Interconexión en el ENS

3.5 Referencias bibliográficas

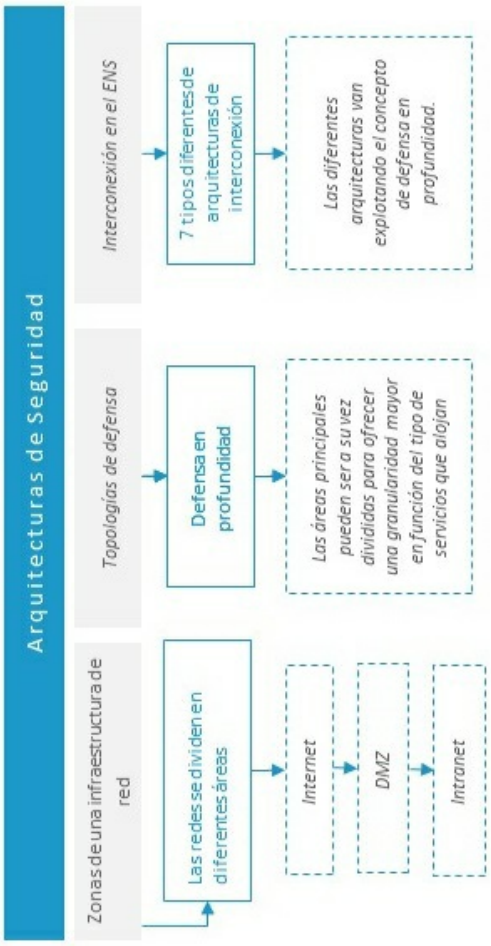
A fondo

Seguridad en redes telemáticas

Demilitarized Zone (DMZ)

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

3.1. Introducción y objetivos

Como se comenta a lo largo de la asignatura, la **finalidad de un cortafuegos** es **bloquear** accesos no autorizados tanto desde el exterior a una red privada o intranet como en el sentido contrario, desde el interior hacia el exterior. Una topología de defensa puede estar formada por un dispositivo o un conjunto de dispositivos que estarán configurados de manera que el tráfico que pase a través de ellos pueda ser limitado, **cifrado o descifrado.** A estos equipos se les conoce normalmente como **equipos bastión,** los cuales cuentan con una fuerte protección, ya que estará expuesto a sufrir ataques desde el exterior, debido a que se encuentran situados entre la red exterior y la red interna.

La **planificación de una arquitectura de seguridad** no es algo trivial, sino que se trata de una tarea delicada, que debe fundamentarse en una política de seguridad definida por la corporación, determinar los responsables y beneficiarios de los servicios, ubicar el cortafuegos en un lugar adecuado y controlar y mantener el correcto funcionamiento de estos, así como de las políticas de seguridad implementadas.

De entre las diversas posibilidades que existen para el despliegue de una arquitectura, dos suelen ser las más utilizadas: las **arquitecturas simples** y las **arquitecturas de defensa en profundidad,** que serán vistas a lo largo de este tema. Además, las arquitecturas de defensa en profundidad pueden estar determinadas por la normativa, como veremos en el caso del ENS.

© Universidad Internacional de La Rioja (UNIR)

3.2. Zonas de una infraestructura de red

Antes de diseñar una arquitectura de seguridad en redes es necesario conocer los diferentes elementos que nos vamos a poder encontrar. Una **infraestructura de red** va a estar compuesta por diferentes segmentos, que de forma general se pueden clasificar en:

- **Internet:** es una red pública a través de la cual viaja el tráfico generado.
- **DMZ:** es lo que se conoce por zona desmilitarizada, y es una red en la que se exponen los servicios que van a ser accesibles desde Internet.
- **Intranet:** es una red interna de una compañía a la que no se permite acceso desde el exterior.

Esta es una clasificación del alto nivel, pero lo más habitual es que cada una de estas zonas esté dividida en diferentes subzonas dependiendo de las necesidades de la empresa. Las zonas más comunes en las que podemos dividir la zona interna de una empresa, que abarca la Intranet y la DMZ, es:

- **DMZ externa:** es la zona en la que van a estar los sistemas expuestos a Internet. Normalmente alberga los servicios que hacen de intermediario para las comunicaciones que salen o entran desde Internet. Es necesario que todo el tráfico sea analizado en esta zona antes de su salida a Internet.
- **Zona empresarial:** es la zona en la que se alojan los sistemas de los usuarios finales, tales como equipos, impresoras o dispositivos de telefonía.
- **Extranet:** es la zona en la que se alojan servicios de terceros en los que tenemos confianza y que normalmente están fuera del control de la organización, por lo que es necesario controlar y filtrar el tráfico que es expuesto en esta zona.
- **DMZ interna:** es la zona en la que se alojan servicios que gestionan el acceso a los

© Universidad Internacional de La Rioja (UNIR)

datos de la zona restringida.

- **Zona restringida:** es la zona en la que se alojan los sistemas críticos y la información sensible, albergando típicamente servidores de bases de datos de usuarios, de recursos humanos, de comercial o propiedad intelectual.

- **Zona de gestión:** es la zona en la que se alojan los servicios de administración y monitorización, tales como sistemas de *log*, de seguridad, de rendimiento, etc. Estos sistemas requieren que los usuarios que los manejan tengan unos permisos elevados para poder llevar a cabo sus tareas, lo que hace que sean un objetivo principal de ataques.

La siguiente figura muestra un esquema de las diferentes zonas y las comunicaciones entre ellas.

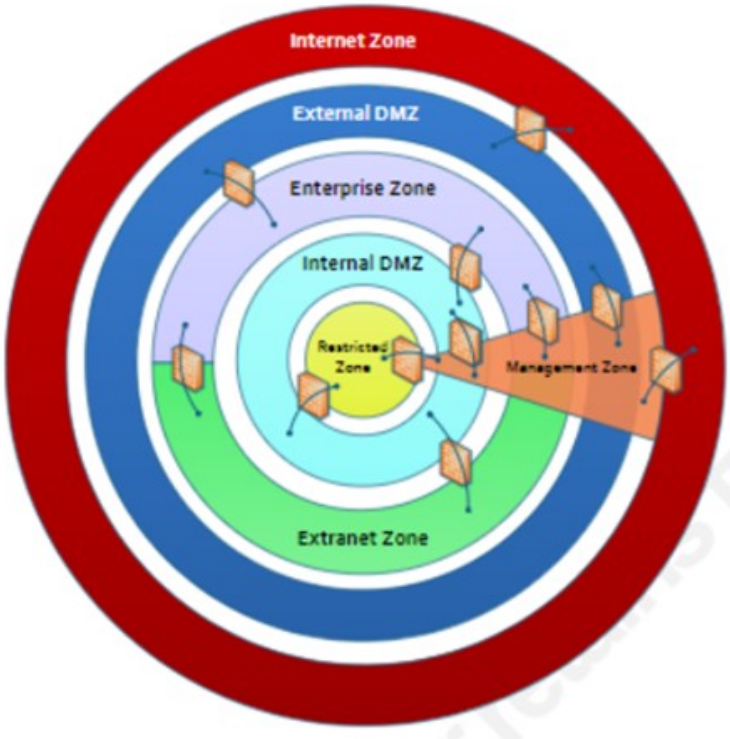


Figura 1. Zonas de seguridad. Fuente: Obregon (2015).

© Universidad Internacional de La Rioja (UNIR)

3.3. Topologías de defensa

Arquitectura simple

Una arquitectura simple es aquella en la que se sitúa el *firewall* o el control de seguridad en la conexión entre la red interna y el medio inseguro al que está conectado (Internet).

El **bastión con interfaz dual** es el intermediario entre la red interna y el exterior, por lo que es el punto crítico de la topología. Si el atacante logra engañar al *firewall*, la red interna podrá ser atacada. Un ejemplo de este tipo de arquitectura puede verse en la siguiente figura.

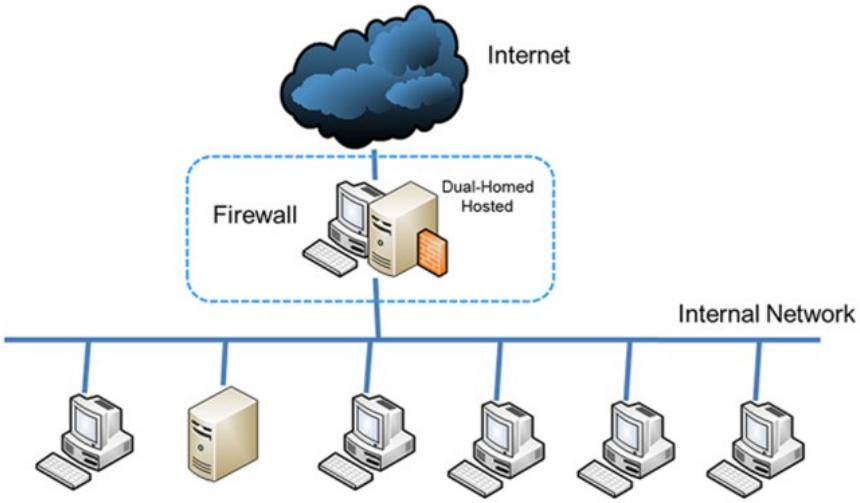


Figura 2. Arquitectura simple. Elaboración propia.

Arquitecturas de defensa en profundidad

Es frecuente conectar el cortafuegos a una tercera red, llamada **Zona Desmilitarizada (DMZ),** en la que se ubican los servidores que deben permanecer accesibles desde la red exterior. En este tipo de técnicas se pueden diferenciar dos zonas en la red interna: la **DMZ o *Perimeter Network*** y la ***Internal Network* o zona**

© Universidad Internacional de La Rioja (UNIR)

de red interior. A esta zona los paquetes ya llegan filtrados desde la zona desmilitarizada.

Esta arquitectura permite mantener segura la red interna a pesar de que un atacante haya logrado infiltrarse en la DMZ.

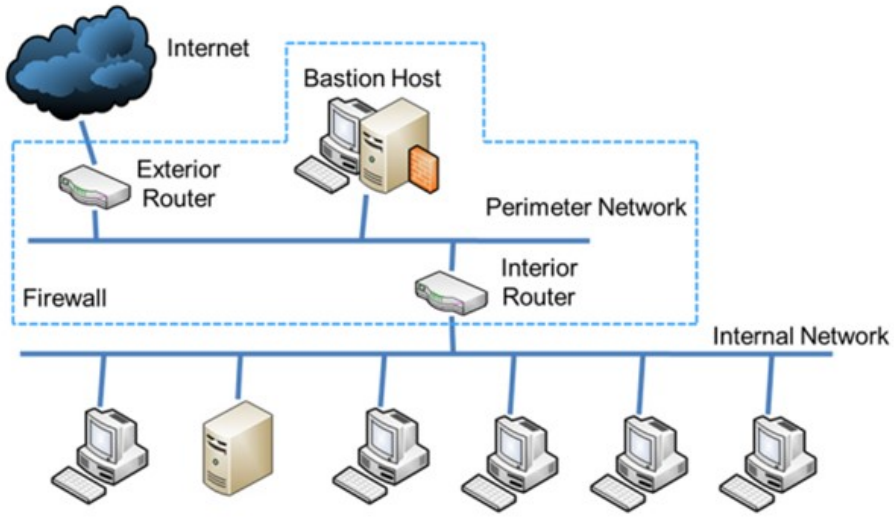


Figura 3. Arquitectura de defensa en profundidad. Elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

3.4 Interconexión en el ENS

Arquitectura de Protección de Perímetro de Tipo 1 (App-1)

Es la arquitectura más básica en la que solamente se utiliza un cortafuegos que está expuesto a Internet, por lo que una vulnerabilidad en este expone toda nuestra infraestructura.

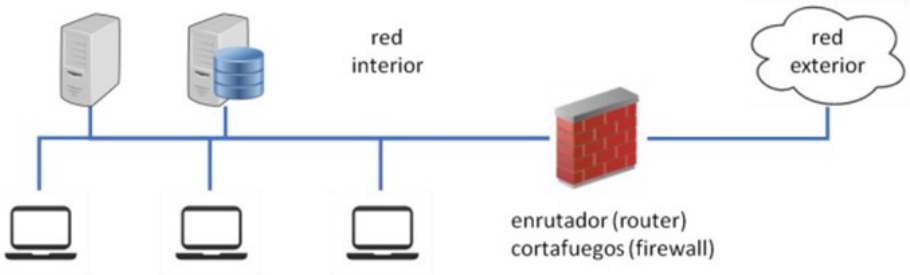


Figura 4. Arquitectura de protección de perímetro tipo -1 (APP-1). Fuente: CCN-STIC-811.

Arquitectura de Protección de Perímetro de Tipo 2 (App-2)

En este caso, en lugar de colocar un *firewall* colocamos un *proxy*, que nos permite monitorizar la información intercambiada y establecer reglas de autorización y registro de datos. Igualmente, como el *proxy* está directamente expuesto a Internet, cualquier vulnerabilidad en él provoca que quede expuesta toda nuestra infraestructura.

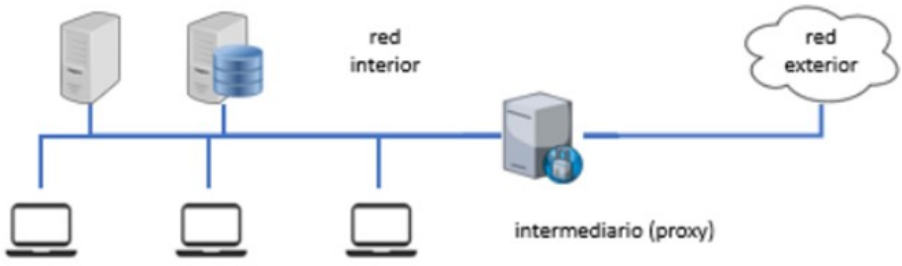


Figura 5. Arquitectura de protección de perímetro tipo -2 (APP-2). Fuente: CCN-STIC-811.

© Universidad Internacional de La Rioja (UNIR)

Arquitectura de Protección de Perímetro de Tipo 3 (App-3)

En esta arquitectura se combina el uso del *firewall* con un *proxy*. El intercambio de datos se realiza a través del *proxy*, lo que permite monitorizar la información intercambiada y establecer reglas de autorización y registro de datos. En este caso, el *firewall* es el que está expuesto a Internet, y una vulnerabilidad en este implica que queda expuesta nuestra infraestructura.



Figura 6. Arquitectura de protección de perímetro tipo -3 (APP-3). Fuente: CCN-STIC-811.

Arquitectura de Protección de Perímetro de Tipo 4 (App-4)

En esta arquitectura, el *proxy* se coloca en la DMZ, que controla a través del *firewall* el tráfico entre las diferentes redes. Los flujos de tráfico permitidos son:

- Entre la red interior y el *proxy*.
- Entre el *proxy* e Internet.
- No debe autorizarse el paso de paquetes directamente desde Internet a la Intranet sin atravesar el *proxy*.

Aunque, al igual que en las arquitecturas anteriores, un error en el *firewall* implica que se vea comprometida nuestra infraestructura, el tráfico que se intercambia entre

© Universidad Internacional de La Rioja (UNIR)

la Intranet e Internet está controlado por el *proxy*. Además, si el intermediario localizado en la DMZ se viese expuesto, su acceso a la red interior estaría limitado por el *firewall*.

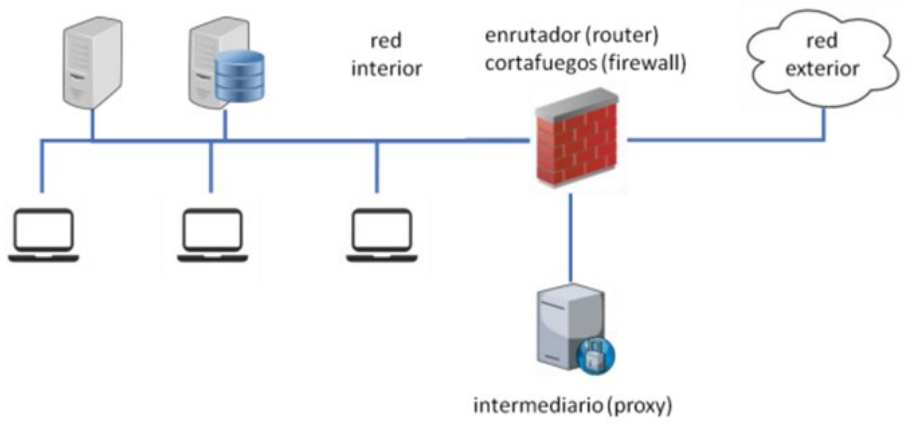


Figura 7. Arquitectura de protección de perímetro tipo -4 (APP-4). Fuente: CCN-STIC-811.

Arquitectura de Protección de Perímetro de Tipo 5 (App-5)

En esta arquitectura, pasamos a tener dos *firewalls* y la DMZ está situada entre ambos. El tráfico no puede circular de forma directa entre ambos *firewalls*, y controla uno de ellos la entrada de datos al *proxy* y el otro la salida de datos de este.

En este caso, para comprometer nuestra infraestructura, el atacante debe comprometer ambos *firewalls*, por lo que, de esta forma, se requeriría que ambos sean de diferentes fabricantes, evitando que con una vulnerabilidad descubierta en uno de ellos podamos atravesar el siguiente.

El tráfico de datos permitidos es igual al de la arquitectura anterior, pasando toda la información a través del *proxy* y no permitiendo conexiones que no pasen a través de este.

© Universidad Internacional de La Rioja (UNIR)

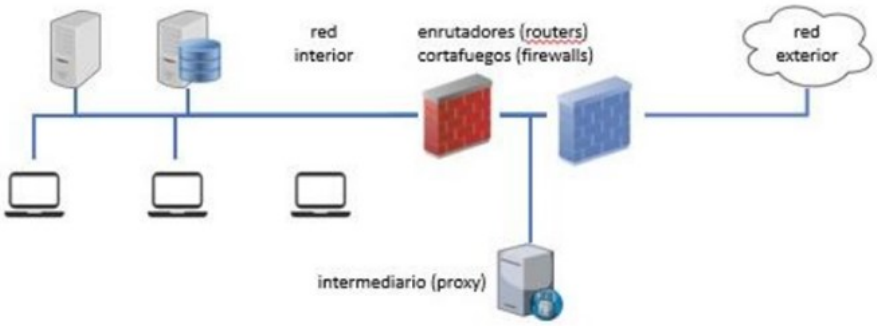


Figura 8. Arquitectura de protección de perímetro tipo -5 (APP-5). Fuente: CCN-STIC-811.

Arquitectura de Protección de Perímetro de Tipo 6 (App-6)

En esta arquitectura se impone que el *proxy* esté colocado entre el *firewall* externo y el interno, por lo que se elimina el requisito de que los *firewalls* sean de diferente fabricante, ya que una vulnerabilidad en el exterior no significa que directamente comprometamos el interior y tengamos acceso a la red interna.

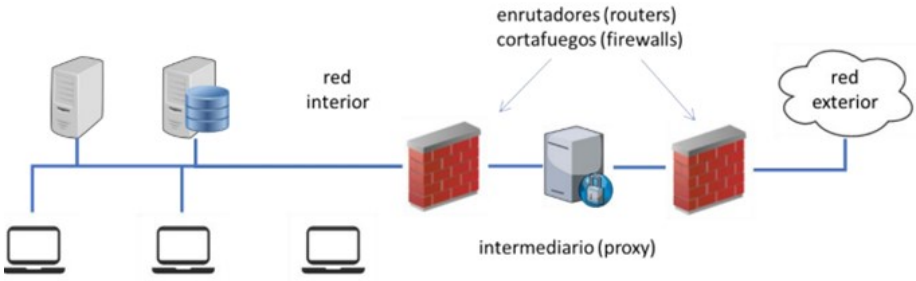


Figura 9. Arquitectura de protección de perímetro tipo -6 (APP-6). Fuente: CCN-STIC-811.

Arquitectura de Protección de Perímetro de Tipo 7 (App-7)

En el caso de redes clasificadas, puede llegar a darse el caso de que el *proxy* se deba sustituir por:

- **Pasarela de intercambio seguro:** están orientadas a la interconexión de redes que manejan información con diferentes políticas de seguridad, como pueda ser

© Universidad Internacional de La Rioja (UNIR)

información con diferentes niveles de clasificación. Para ello estos dispositivos rompen los protocolos de la capa OSI entre dos redes que se interconectan y las comunican a través de un dispositivo pasivo de lectura y escritura. Además, analizan el contenido intercambiado para evitar la fuga de datos.

- **Diodo:** dispositivo que garantiza el flujo unidireccional de la información mediante *hardware*, al no existir un canal de retorno físico.

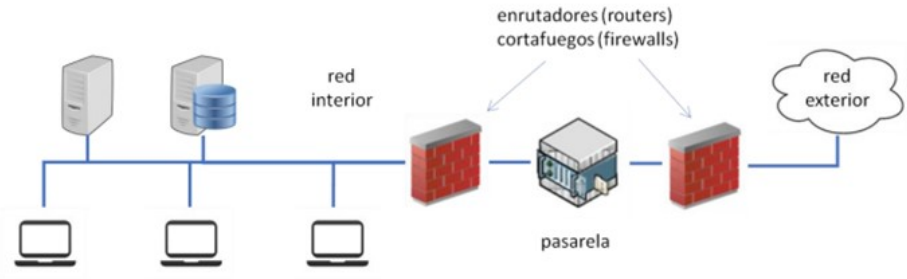
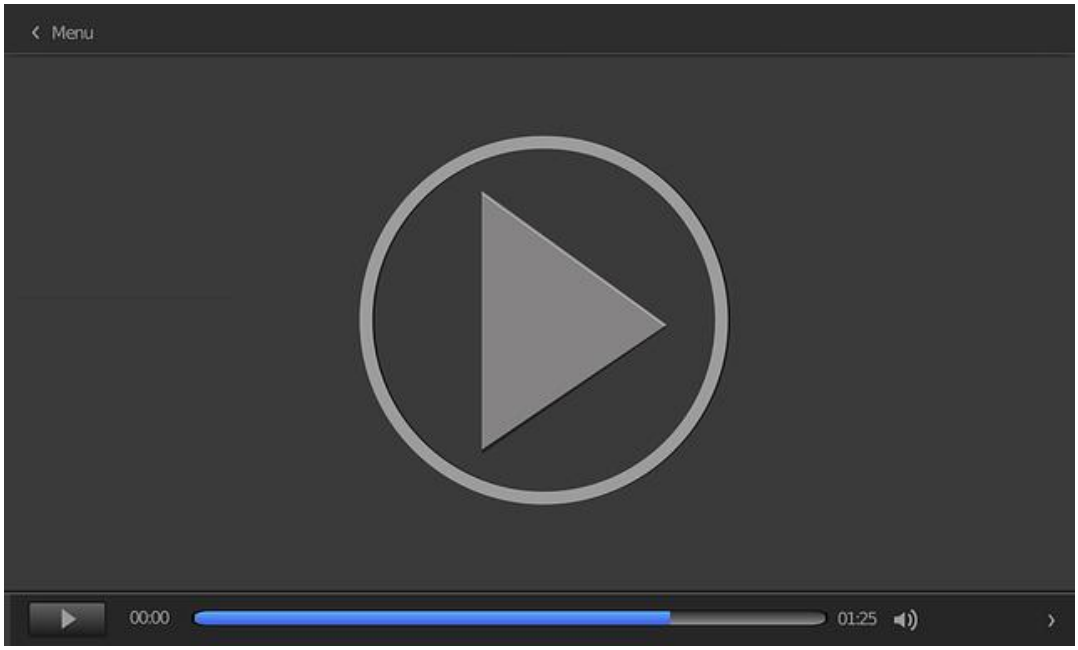


Figura 10. Arquitectura de protección de perímetro tipo -7 (APP-7). Fuente: CCN-STIC-811.

En el vídeo, *Catálogo de Productos de Seguridad TIC para herramientas de seguridad perimetral*, se hace un análisis de productos cualificados para la protección de las comunicaciones.



© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=1e3d833d-d31a-43d6-b388-af63012cd1af

© Universidad Internacional de La Rioja (UNIR)

3.5 Referencias bibliográficas

CCN. (2017, octubre). *CCN-STIC 811 - Interconexión en el ENS* de https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/521-ccn-stic-811-interconexion-en-el-ens/file.html

Obregon, L. (2015). *Infrastructure security architecture for effective security monitoring.* SANS Institute, Dec, 2.

© Universidad Internacional de La Rioja (UNIR)

Seguridad en redes telemáticas

Carracedo Gallardo, J. (2004). *Seguridad en redes telemáticas.* McGraw-Hill.

Libro que abarca numerosos conceptos relacionados con la seguridad en redes. El segundo capítulo posee un repaso interesante relativo a la ubicación de los servicios de seguridad.

© Universidad Internacional de La Rioja (UNIR)

Demilitarized Zone (DMZ)

Kan, D. (2015, March 2). *Demilitarized Zone (DMZ)*. https://www.youtube.com/watch?v=rztA1D5h_Ec

En este vídeo de YouTube se explica qué es una DMZ y para qué sirve.

© Universidad Internacional de La Rioja (UNIR)

Test

1. Una DMZ:

   A. Recibe conexiones desde la Intranet.

   B. Recibe conexiones desde Internet.

   C. Las respuestas A y B son correctas.

   D. Ninguna de las anteriores.

2. La zona de gestión:

   A. Es transversal al resto de zonas de la red.

   B. Se utiliza para desplegar aplicaciones del departamento de recursos humanos.

   C. No se debe contemplar nunca la existencia de una zona de este tipo en una arquitectura de red segura.

   D. Ninguna de las anteriores.

3. La DMZ interna:

   A. Es la zona en la que se alojan servicios que gestionan el acceso a los datos de la zona restringida.

   B. Permite el acceso desde el exterior.

   C. Las respuestas A y B son correctas.

   D. Ninguna de las anteriores.

4. Un equipo bastión:

   A. Es un equipo que debe estar bien protegido, ya que es un punto crítico de la infraestructura.

   B. Es un equipo que únicamente monitoriza el tráfico, pero no lo restringe.

   C. Es un equipo que no debe estar bien protegido para atraer a los atacantes.

   D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

5. Cuando tenemos una arquitectura protegida por dos *firewalls*, en el ENS se determina que:

A. Siempre deben ser de diferentes fabricantes.

B. Siempre deben ser del mismo fabricante.

C. No se deben utilizar dos *firewalls* para proteger nuestra infraestructura.

D. Ninguna de las anteriores.

6. En una arquitectura protegida por un único *firewall*:

A. Si este se ve comprometido, el atacante no tiene acceso a nuestra infraestructura.

B. No se permiten en el ENS bajo ningún concepto arquitecturas con un único *firewall*.

C. Las respuestas A y B son correctas.

D. Ninguna de las anteriores.

7. El ENS establece que:

A. Es requisito utilizar un *proxy* y un *firewall* siempre.

B. No se puede combinar la utilización de un *proxy* y un *firewall*.

C. Requiere la utilización de la protección mediante diodos.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

8. El tráfico permitido en la Arquitectura de Protección de Perímetro de Tipo 4 (App-4):

A. Entre la red interior y el intermediario o *proxy*.

B. Entre el intermediario (*proxy*) y la red exterior.

C. Las respuestas A y B son correctas.

D. Ninguna de las anteriores.

Pasarela de intercambio seguro: están orientadas a la interconexión de redes que manejan información con diferentes políticas de seguridad, como pueda ser información con diferentes niveles de clasificación. Para ello estos dispositivos rompen los protocolos de la capa OSI entre dos redes que se interconectan y las comunican a través de un dispositivo pasivo de lectura y escritura. Además, analizan el contenido intercambiado para evitar la fuga de datos.

Diodo: dispositivo que garantiza el flujo unidireccional de la información mediante hardware, al no existir un canal de retorno físico.

9. Una pasarela de intercambio seguro:

A. Están orientadas a la interconexión de redes que manejan información con diferentes políticas de seguridad.

B. Es obligado su uso en el ENS.

C. Las respuestas A y B son correctas.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

10. Una Diodo:

A. Es un dispositivo que garantiza el flujo unidireccional de la información mediante *hardware*, al no existir un canal de retorno físico.

B. Permite evitar fugas de información.

C. Las respuestas A y B son correctas.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)